MICROSOFT 365 SECURITY RECOMMENDATIONS - SECURITY BRIEF

Name: KANISHAK GADHAVI | Role/Cohort: M365 security consultant

Organization: Skilling Challenge tenant | Date: 25 October 2026

Scenario and approach

The client is a business with 100 users, two administrators and Microsoft 365 E7 licenses. E7 already includes the E5 security stack (Defender XDR, Intune, Purview, Entra ID P2), the Entra Suite, Microsoft 365 Copilot and Agent 365. The gap is not licensing; it is that two people must switch these tools on safely. I ranked controls by the risk they remove, weighed against the effort to run them. Most small-business breaches follow one chain: a stolen identity or phishing email, then an over-privileged account or unmanaged device, then data loss. My ranking follows that chain. I tested the identity controls in a lab tenant, and those results shaped the rollout advice below.

1. Conditional Access identity baseline

Why it matters: Password spray, credential stuffing and phishing are the most common ways in. Microsoft reports that MFA blocks over 99% of automated account attacks. Blocking legacy protocols (IMAP, POP, SMTP AUTH, basic-auth ActiveSync) closes the path that skips MFA entirely. Risk-based policies use Entra ID Protection to challenge suspicious sign-ins and force remediation when credentials leak.

Rollout with two admins: First, create two cloud-only break-glass accounts protected by FIDO2 keys and excluded from every policy through one role-assignable group. Then build four policies from Microsoft templates: MFA for all users, block legacy authentication, MFA for medium and high sign-in risk, and risk remediation for high user risk. Use authentication strengths, not the legacy MFA checkbox. Run each in report-only for a week, check the What If tool, then enable one at a time.

Tradeoffs: Every user must register a method, and old printers or scripts using SMTP AUTH will break. Help desk calls rise in the first week, and risk policies produce some false positives.

2. Privileged access protection

Why it matters: With only two admins, one compromised admin account means the whole tenant: mail, files and every security setting. Standing Global Administrator rights also magnify honest mistakes.

Rollout with two admins: Give each admin a separate cloud-only admin account protected by a passkey. Use Privileged Identity Management so roles are eligible and activated for a few hours with a justification. Use task roles such as Conditional Access Administrator instead of Global Administrator. Alert on every break-glass sign-in.

Tradeoffs: Activation adds a minute to each admin task. With two people, approval workflows slow work and depend on the other admin being available, so I would require approval only for Global Administrator. A lost passkey needs a Temporary Access Pass recovery process.

Lab lesson: In my lab, every policy quietly excluded the Global Administrator role. The score said "implemented" while the most powerful accounts were unprotected. Always read the exclusions, not just the score.

3. Email and collaboration threat protection

Why it matters: Phishing and business email compromise, especially invoice fraud, cost small businesses the most money. Defender for Office 365 Safe Links, Safe Attachments and impersonation protection stop malicious content before a user clicks, including in Teams and SharePoint.

Rollout with two admins: Apply the Standard preset security policy to all users and Strict to admins and finance staff. Microsoft maintains these presets, so there is little tuning. Turn on automated investigation and response so Defender cleans up threats instead of the admins. Configure SPF, DKIM and DMARC, and run attack simulation training each quarter.

Tradeoffs: Attachment scanning can delay some mail by seconds. False positives quarantine legitimate messages, so someone must review quarantine. Training takes staff time.

4. Device compliance with Intune and Defender for Endpoint

Why it matters: A session token stolen from an infected laptop bypasses MFA. Requiring managed, healthy devices blocks access from compromised or personal machines and adds endpoint detection and response.

Rollout with two admins: Enroll Windows devices with Autopilot, apply Microsoft security baselines, and onboard Defender for Endpoint through Intune. Define compliance (encryption, current OS, antivirus, device risk), then require compliant devices in Conditional Access, starting with admins. Use app protection policies for personal phones instead of full enrollment.

Tradeoffs: This is the most effort of the five. Staff may resist enrolling devices, and non-compliant devices get blocked. I would phase it over 60 to 90 days.

5. Data and app governance for Copilot and agents

Why it matters: E7 includes Copilot and agents, which find and summarize anything a user can access. Overshared sensitive data becomes easy to surface. Malicious OAuth apps can also read mail without ever knowing a password.

Rollout with two admins: Turn off user consent and enable the admin consent workflow. Publish four sensitivity labels (Public, General, Confidential, Highly Confidential) with a default label and auto-labeling for obvious data such as card numbers. Use Purview oversharing reports to fix broadly shared sites before widening Copilot. Start DLP in simulation, then enforce it for Highly Confidential content. Allow only approved agents through Agent 365.

Tradeoffs: Labels need user training, DLP false positives frustrate staff, and app approvals delay new tools.

What did not make the top five

Self-service password reset and Teams meeting controls (invited-only lobby bypass, organizer-only presenters, no anonymous join) are quick wins I would apply in the first week, but they remove less risk than the five above.

How this scales

Every control targets All users or groups, not named people, so new hires are protected on day one. Exclusions stay limited to one monitored break-glass group. As the company grows past two admins, PIM approval, access reviews and separate admin tiers become practical, and the same policies extend without redesign. Phishing-resistant MFA for every user is the next step once registration is complete.

90-day plan

Weeks 1-2: break-glass accounts, separate admin accounts, PIM, report-only policies and Defender presets. Weeks 3-6: enforce Conditional Access, run an MFA registration campaign, configure email authentication and apply quick wins. Weeks 7-12: device compliance, then labels, DLP and wider Copilot use. Secure Score tracks progress, but each control is proven with sign-in logs and real tests, not the score alone.

Signature: KANISHAK GADHAVI